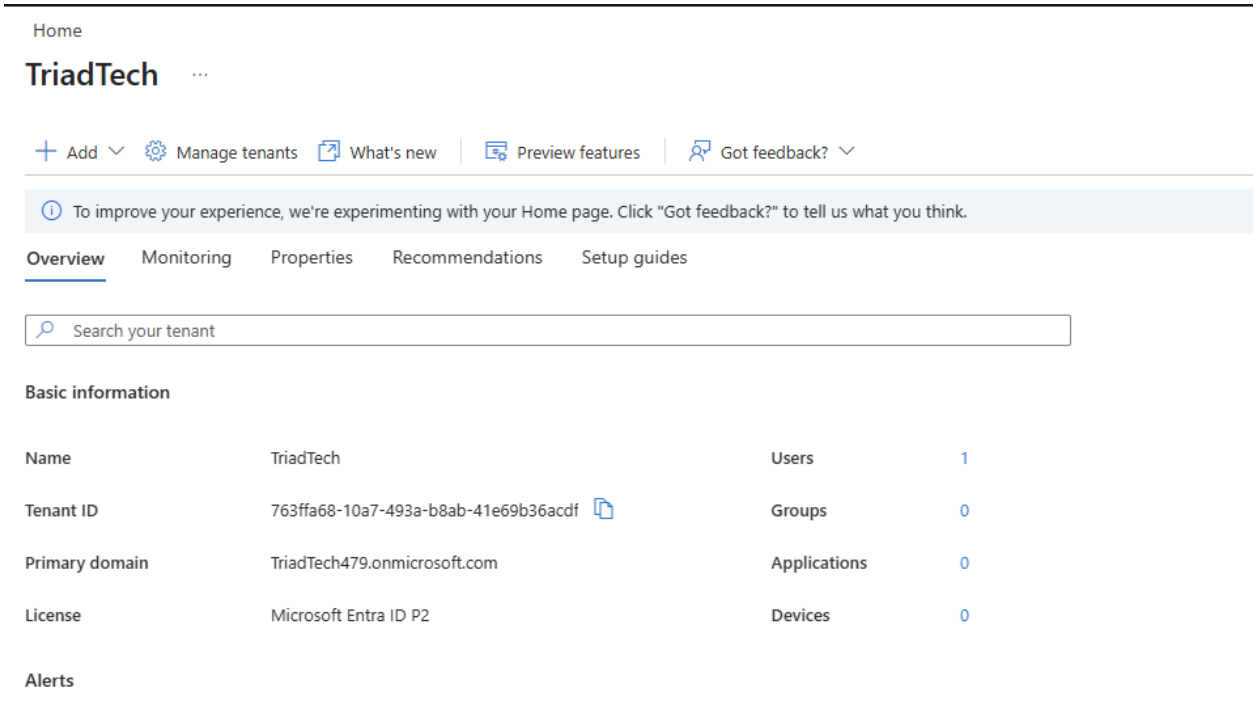
Project Overview

This is a writeup of a simulated enterprise IAM environment.

Phase 0 - Environment Setup

I utilized a student account for Azure for the purposes of this project. As a current student, I was able to get $100 worth of credits for Azure.

The project required me to utilize Entra ID. I used a free license for Microsoft Entra ID P2 to utilize advanced security like risk-based Conditional Access, and Privileged Identity Management (PIM). I create the tenant TriadTech, and would use that as the name of my mock company going forward.



Phase 1 - Creation of the Fake Company

This phase required creation of a fake company for this enterprise environment. I created TriadTech, and envisioned it as a New York City based technology consulting company. I envisioned it as a small to medium sized company, with 200 users, but only around 30 were created for the purposes of this project.

The following were the departments with the number of users:

Consulting & Client Delivery: 8 users
Engineering & Technology: 6 users
Sales & Business Development: 5 users
HR & People Operations: 4 users
IT & Infrastructure: 4 users
Finance & Operations: 3 users
Executive Leadership: 3 users

I used the 'bulk create users' option in Entra in order to create this mock company's employees. I utilized this link to learn what was necessary for the users.csv file. To save time, I utilized Claude to generate a users.csv file with all the fields filled in.

Bulk create users

Please be aware of the bulk operations service limitations before using this feature. Operations can only run for up to 1 hour and has known issues in large tenants. Click here to learn more.

1. Download csv template (optional)

Download

2. Edit your csv file

3. Upload your csv file

"users.csv"

File uploaded successfully

In progress

Click here to view the status of each operation

Learn more about bulk import users

Submit

TM	TT_Aisha Mensah	aisha.mensah@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TN	TT_Ben Nakamura	ben.nakamura@Tr...	Member	No	No	TriadTech479.onmicrosoft.com
TS	TT_Brianna Scott	brianna.scott@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TR	TT_Carmen Ruiz	carmen.ruiz@Tria...	Member	No	No	TriadTech479.onmicrosoft.com
TV	TT_Christine Voss	christine.voss@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TF	TT_Connor Flynn	connor.flynn@Tria...	Member	No	No	TriadTech479.onmicrosoft.com
TK	TT_Dana Kowalski	dana.kowalski@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TP	TT_Derek Patel	derek.patel@Triad...	Member	No	No	TriadTech479.onmicrosoft.com
TB	TT_Ethan Brooks	ethan.brooks@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TG	TT_Fiona Gallagher	fiona.gallagher@T...	Member	No	No	TriadTech479.onmicrosoft.com
TT	TT_Grace Thornton	grace.thornton@T...	Member	No	No	TriadTech479.onmicrosoft.com
TY	TT_Hannah Yoon	hannah.yoon@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TM	TT_Isla MacLeod	isla.macleod@Tria...	Member	No	No	TriadTech479.onmicrosoft.com
TC	TT_James Carter	james.carter@Tria...	Member	No	No	TriadTech479.onmicrosoft.com

After the users were created, I created 7 security groups based on the above departments and assigned each user to their respective group.

New group | Download groups | Refresh | Manage view | Delete | Got feedback?

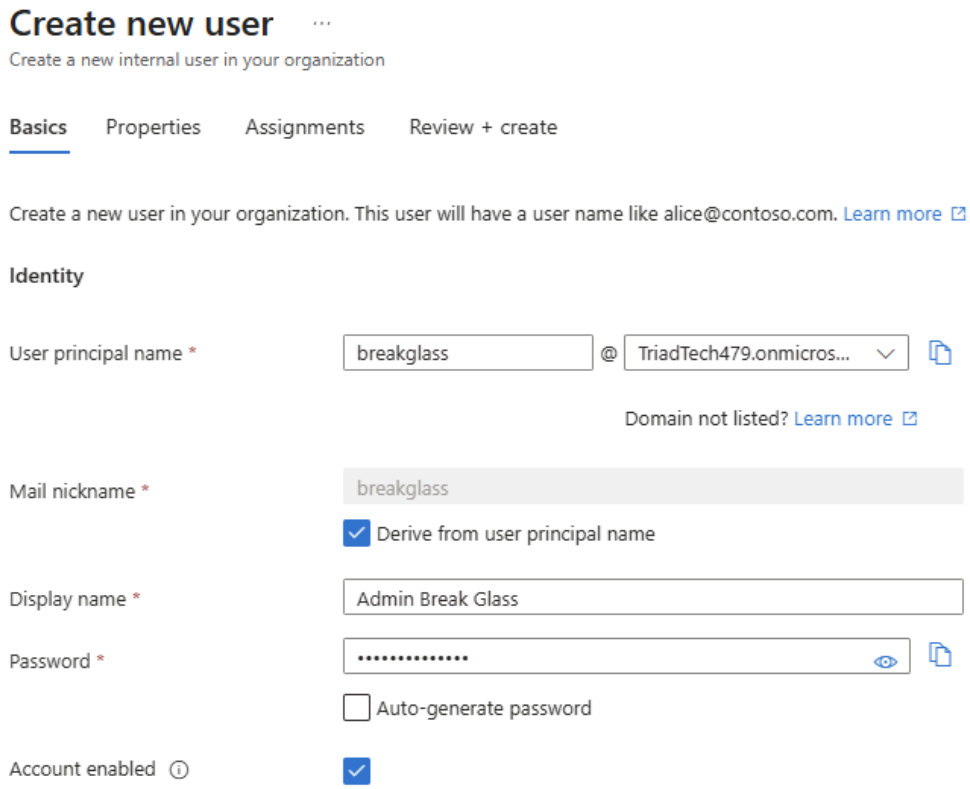
Search | Add filter

Search mode: Contains

7 groups found

Name ↑	Object Id	Group type	Membership type	Email
C& Consulting & Client Delivery	411873e7-16f4-466b-8918-7fb8f25688b5	Security	Assigned	
E& Engineering & Technology	a567cfc2-f82b-483c-90e1-c7c17153bbaf	Security	Assigned	
EL Executive Leadership	2d0cc096-18ba-411f-ba3f-9c7207905eff	Security	Assigned	
F& Finance & Operations	fcdfc9d6-c53a-4666-a2fe-99f553b6ae4d	Security	Assigned	
H& HR & People Operations	3ebed33b-dbbb-4900-ac00-26a31bd38d09	Security	Assigned	
I& IT & Infrastructure	60814e70-9009-4268-b09c-e9bd9a1a97fb	Security	Assigned	
S& Sales & Business Development	06c38339-6e8c-4b97-b890-eaf920aba27b	Security	Assigned	

And finally I created a “Break Glass” admin account.



Phase 2 - Role-Based Access Control (RBAC)

The groups created in the first phase were meant to simulate a strict organizational hierarchy. 'X belongs to Y department'. The purpose of this phase is to demonstrate principle of least privilege in a controlled setting.

These were the RBAC groups created, along with descriptions:
Consulting_ReadOnly — *"Grants read-only access to client delivery resources for consulting staff. No write or delete permissions permitted."*
Engineering_Dev — *"Grants access to development environments and internal engineering tooling. Scoped to Engineering & Technology department."*
BD_CRM — *"Grants access to CRM platform and sales pipeline data. Scoped to Sales & Business Development department only."*
HR_SensitiveAccess — *"Grants access to sensitive employee records and PII. Restricted to HR & People Operations staff. High sensitivity group."*

IT_Helpdesk — *"Grants helpdesk-level permissions including password reset and basic user management. No access to security or admin configurations."*
Finance_ReadOnly — *"Grants read-only access to financial reports and billing data. No edit permissions. Scoped to Finance & Operations department."*
Executive_Restricted — *"Grants broad organizational access for executive leadership. Subject to strictest Conditional Access controls including MFA and compliant device requirement."*

7 groups found

Name ⇅	Object Id	Group type	Membership type	Email
BD_CRM	32b48991-4785-465f-a517-496192314f14	Security	Assigned	
Engineering_Dev	34b1c834-a18c-4273-9173-023cf1296b9d	Security	Assigned	
HR_SensitiveAccess	7a3320b2-5167-455a-9bec-cc83dd6a83ff	Security	Assigned	
Executive_Restricted	9e113007-6083-46a3-9c11-b6202612b33d	Security	Assigned	
Finance_ReadOnly	c077b6ed-489b-484b-aebf-38e3beba8ef3	Security	Assigned	
IT_HelpDesk	d7c7aa91-1f5c-4b1f-95b0-c9d0f47d933c	Security	Assigned	
Consulting_ReadOnly	d85f6f93-6ac1-4587-bce7-0a99800e3c79	Security	Assigned	

I did not assign Entra ID roles for the creation of these RBAC groups because this is just a lab environment.

Phase 3 — Privileged Access Model

For this phase, two admin level users, Admin01 and Admin02 were created.

Home › Roles and administrators | All roles › Users

Create new user

Create a new internal user in your organization

Basics | Properties | Assignments | **Review + create**

Basics

User principal name	admin01@TriadTech479.onmicrosoft.com
Display name	Admin 01
Mail nickname	admin01
Password	••••••••••
Account enabled	Yes

Properties

User type	Member

Assignments

Administrative units

Groups

Roles

Then I assigned these admins to the Global Administrator role, and assigned users based on departments to other roles, such as Helpdesk Administrator, Security Reader,

Home › Roles and administrators | All roles › Users

Roles and administrators | All roles

TriadTech

All roles
Admin units
Protected actions
Diagnose and solve problems

Activity
Access reviews
Audit logs

Troubleshooting + Support
New support request

New custom role | Delete custom role | Download assignments | Refresh | Preview features | Got feedback?

Get just-in-time access to a role when you need it using PIM. Learn more about PIM →

Your Role: Global Administrator and 1 other roles

Administrative roles

Administrative roles are used for granting access for privileged actions in Microsoft Entra ID. We recommend using these built-in roles for delegating access to manage broad application configuration permissions without granting access to manage other parts of Microsoft Entra ID not related to application configuration. Learn more.

Learn more about Microsoft Entra ID role-based access control

Search by name or description | Add filters

Role	Description	Privileged	Ass...	Type
Agent ID Administrator	Manage all aspects of agents in a tenant including identity lifecycle operations for agent blueprints, agent service principals, agent identities, and agentic users.		0	Built-in
Agent ID Developer	Create an agent blueprint and its service principal in a tenant. User will be added as an owner of the agent blueprint and its service principal.		0	Built-in
Agent Registry Administrator	Manage all aspects of the Agent Registry service in Microsoft Entra ID		0	Built-in
AI Administrator	Manage all aspects of Microsoft 365 Copilot and AI-related enterprise services in Microsoft 365.		0	Built-in
Application Administrator	Can create and manage all aspects of app registrations and enterprise apps.	PRIVILEGED	0	Built-in
Application Developer	Can create application registrations independent of the 'Users can register applications' setting.	PRIVILEGED	0	Built-in
Attack Payload Author	Can create attack payloads that an administrator can initiate later.		0	Built-in
Attack Simulation Administrator	Can create and manage all aspects of attack simulation campaigns.		0	Built-in
Attribute Assignment Administrator	Assign custom security attribute keys and values to supported Microsoft Entra objects.		0	Built-in
Attribute Assignment Reader	Read custom security attribute keys and values for supported Microsoft Entra objects.		0	Built-in
Attribute Definition Administrator	Define and manage the definition of custom security attributes.		0	Built-in
Attribute Definition Reader	Read the definition of custom security attributes.		0	Built-in
Attribute Log Administrator	Read audit logs and configure diagnostic settings for events related to custom security attributes.		0	Built-in
Attribute Log Reader	Read audit logs related to custom security attributes.		0	Built-in
Attribute Provisioning Administrator	Read and edit the provisioning configuration of all active custom security attributes for an application.	PRIVILEGED	0	Built-in

Home › Roles and administrators | All roles › Users › Roles and administrators | All roles › Users › Admin 01 › Roles and administrators | All roles › Helpdesk Administrator

Helpdesk Administrator | Assignments

All roles

Diagnose and solve problems

Manage
Assignments
Description

Activity
Bulk operation results

Troubleshooting + Support
New support request

Add assignments | Remove assignments | Download assignments | Refresh | Manage in PIM | Got feedback?

You can also assign built-in roles to groups now. Learn More

Search
Search by name

Type
All

Name	UserName	Type	Scope
TT_Raj Kapoor	raj.kapoor@TriadTech479.onmicrosoft.com	User	Directory
TT_Zoe Harrington	zoe.harrington@TriadTech479.onmicrosoft.com	User	Directory
TT_Marcus Hill	marcus.hill@TriadTech479.onmicrosoft.com	User	Directory

Then I configured Privileged Identity Management.

Home › Roles and administrators | All roles › Users › Roles and administrators | All roles › Global Administrator | Assignments

Privileged Identity Management | Quick start

Privileged Identity Management

- Quick start

Tasks

- My roles
- My requests
- Approve requests
- Review access

Manage

- Microsoft Entra roles
- Groups
- Azure resources

Activity

- My audit history

Troubleshooting + Support

- Troubleshoot
- New support request

What's new | Get started

Manage your privileged access

Use Privileged Identity Management to manage the lifecycle of role assignments, enforce just-in-time access policy, and discover who has what roles. Learn more

Manage access

Users with excessive access are vulnerable in the event of account compromise. Ensure your organization manages to least privilege by periodically reviewing, renewing, or extending access to resources.

Manage

Activate just in time

Reduce the potential for lateral movement in the event of account compromise by eliminating persistent access to privileged roles and resources. Enforce just in time access to critical roles with PIM.

Activate

Discover and monitor

It is common for access to critical resources to go undetected. Ensure you know who has access to what, and receive notifications when new assignments are granted to accounts in your organization.

Discover

Edit role setting - Global Administrator

Privileged Identity Management | Microsoft Entra roles

Activation | Assignment | Notification

Activation maximum duration (hours)

8

On activation, require

- ○ None
- ◉ Azure MFA
- ○ Microsoft Entra Conditional Access authentication context

Learn more

- [x] Require justification on activation
- [ ] Require ticket information on activation
- [x] Require approval to activate

Select approver(s)

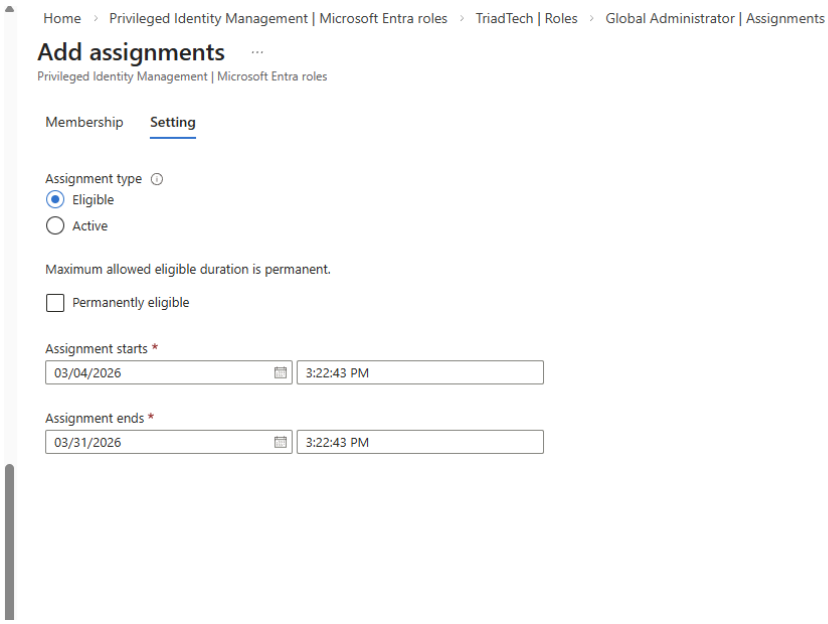
2 Member(s), 0 Group(s) selected

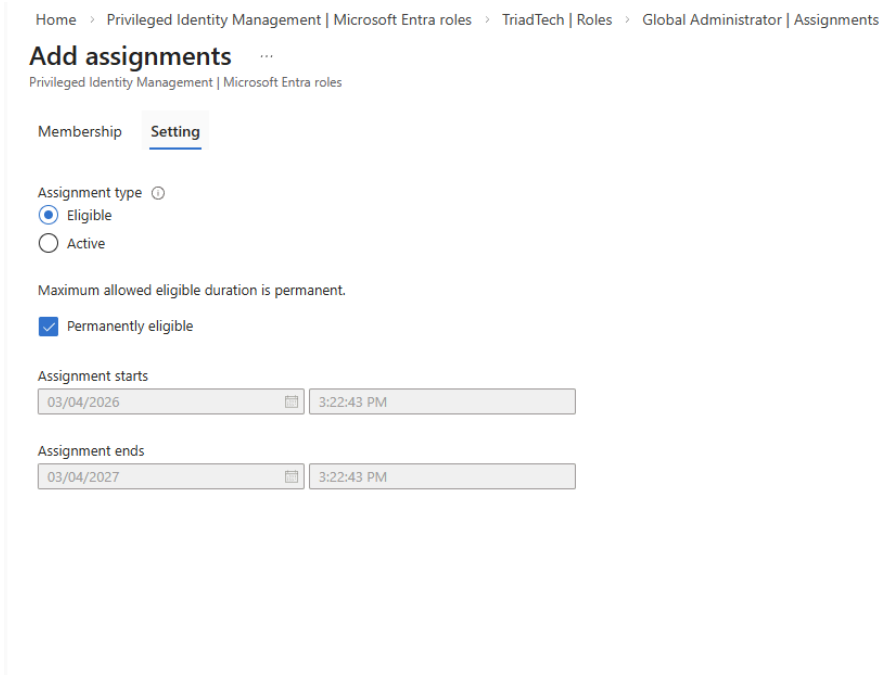
If no specific approvers are selected, privileged role administrators/global administrators will become the default approvers.

Selected approvers:

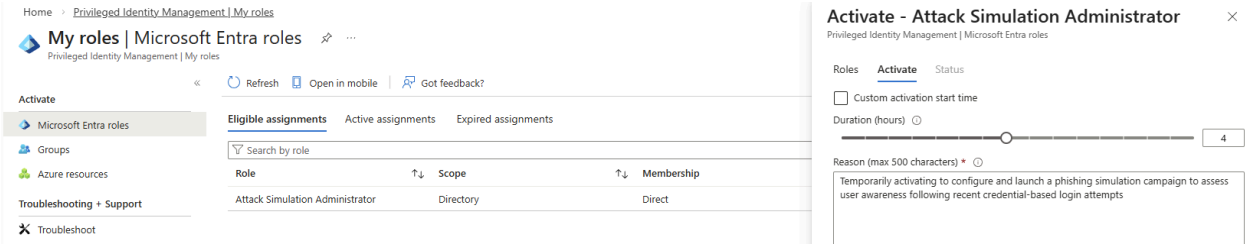
Luke Gearty LukeGearty@TriadTech479.onmicrosoft.com	Remove
Admin 2 admin02@TriadTech479.onmicrosoft.com	Remove

Update | Next: Assignment





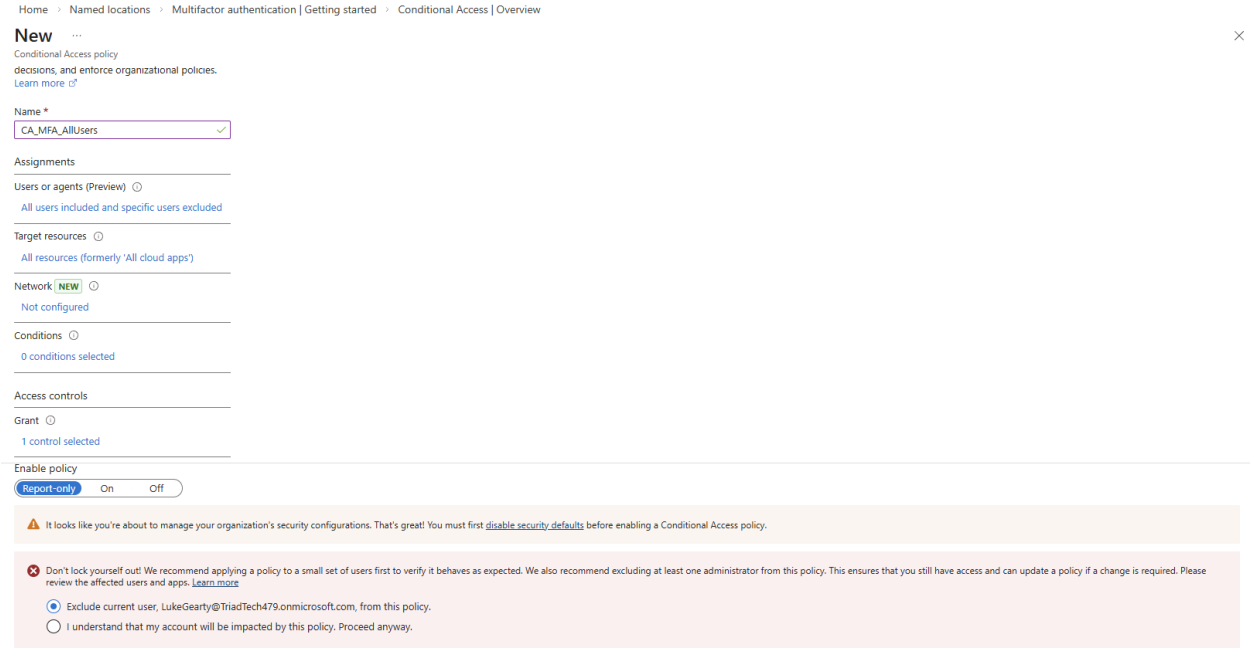
I then configured a JIT for a sample role. I used my own account as the test, as anything else would require MFA from other sample users.



Technically I would prefer to do a Global Admin as a temporary role for better security purposes, but for the purposes of this lab I used another role.

Phase 4 — Conditional Access Policies

I then created the Conditional Access Policies. All policies were started in report mode only. The first policy was enforcing MFA for all users, except for the Admin Break Glass (and my own).



The next was blocking legacy authentication.

Home › Users › TT_Adrian Mercer | Sign-in logs › Conditional Access | Policies

New ...

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. Learn more

Name *

CA_Block_LegacyAuth

Assignments

Users or agents (Preview)

All users included and specific users excluded

Target resources

All resources (formerly 'All cloud apps')

Network NEW

Not configured

Conditions

1 condition selected

Access controls

Grant

0 controls selected

Session

0 controls selected

Control access based on signals from conditions like risk, device platform, location, client apps, or device state. Learn more

User risk

User risk level is the likelihood that the user account is compromised.

Not configured

Sign-in risk

Sign-in risk level is the likelihood that the sign-in session is compromised.

Not configured

Insider risk

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.

Not configured

Device platforms

Not configured

Locations

Not configured

Client apps

2 included

Filter for devices

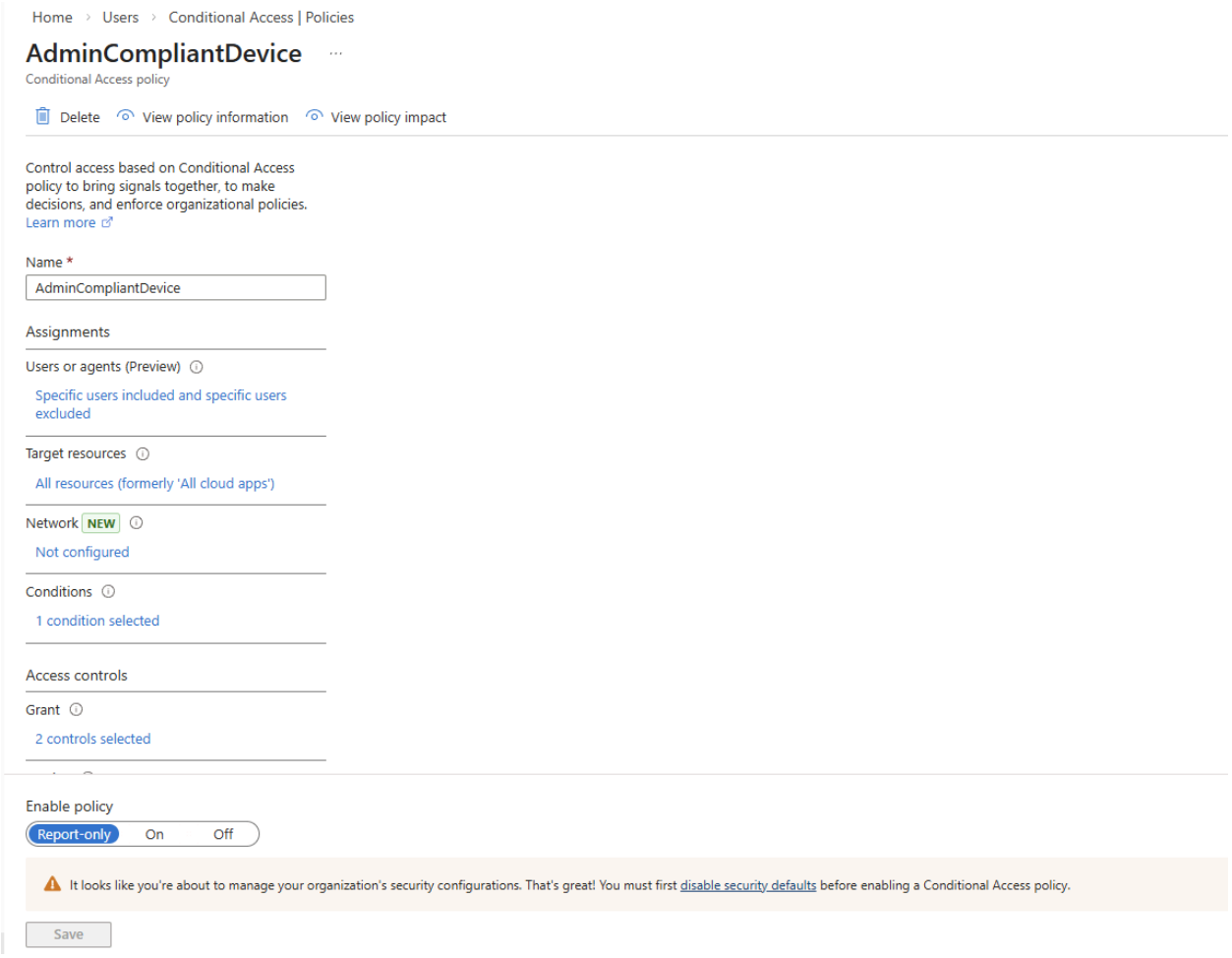
Enable policy

Report-only On Off

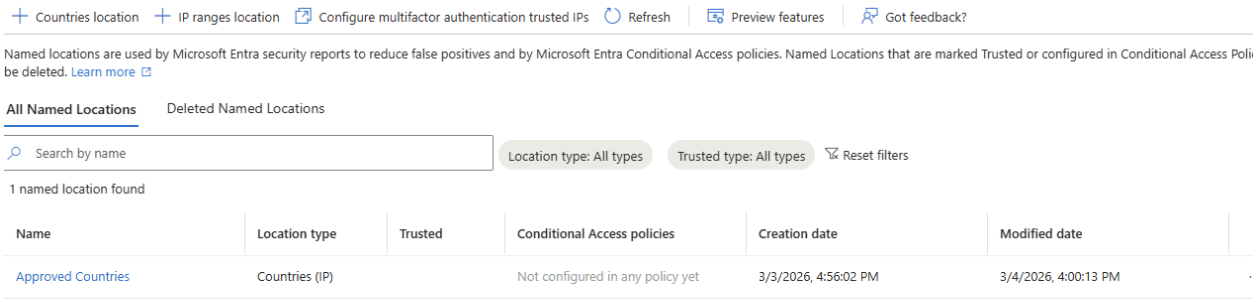
It looks like you're about to manage your organization's security configurations. That's great! You must first disable security defaults before enabling a Conditional Access policy.

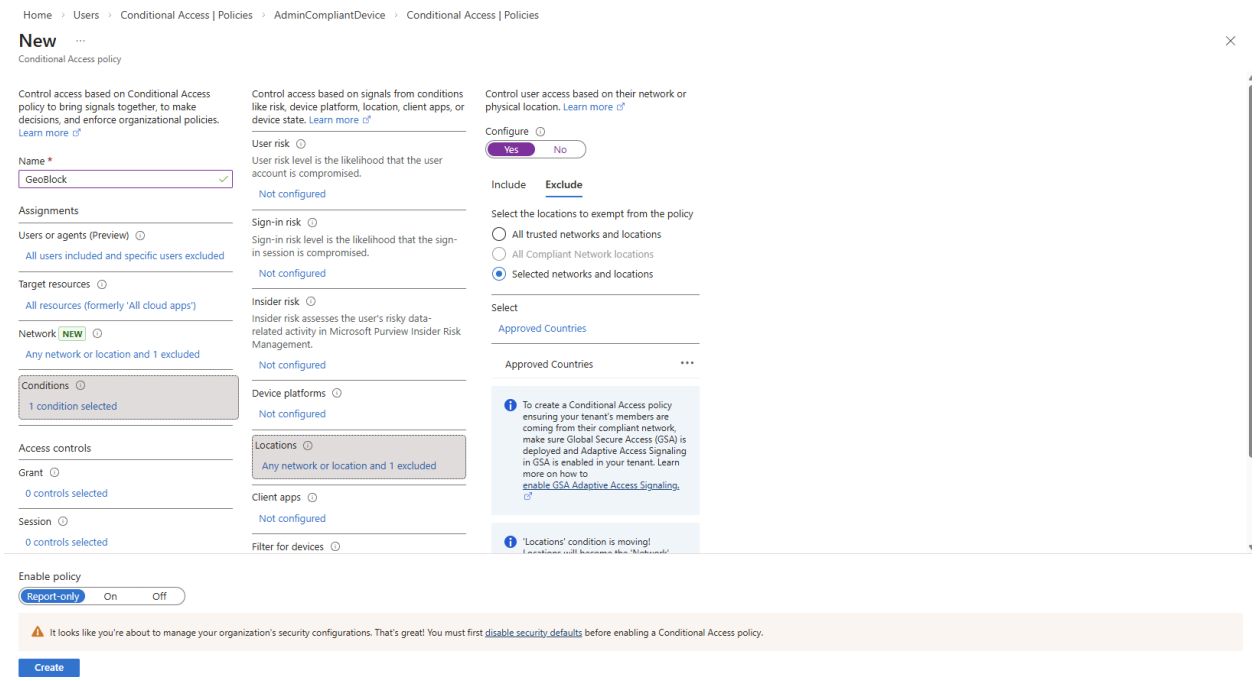
Create

The next was to ensure that admin roles like Global Administrator could only login from compliant devices.

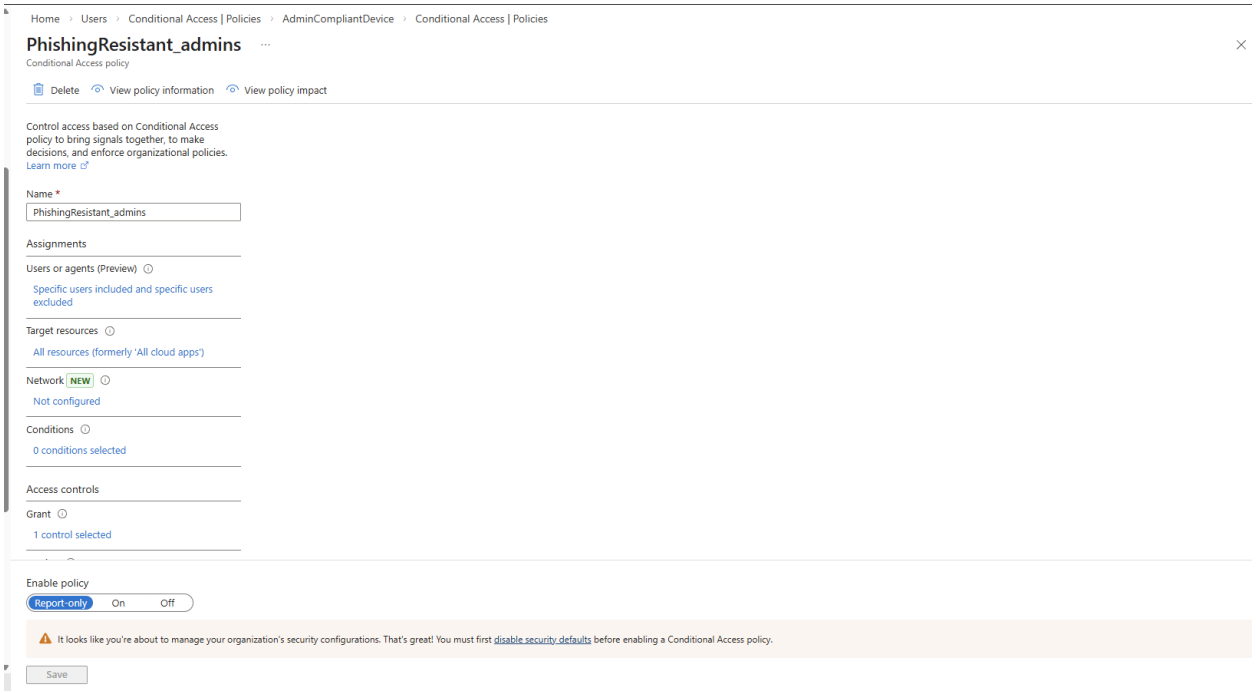


The next was to block logins from untrusted countries. The countries my mock company operated in were the USA, the UK, and Canada. For security, any country outside of those three would be blocked.





Next was to enable phishing resistant MFA for admin roles.



And the final CA was to Block High Risk logins.

Home › Users › Conditional Access | Policies

BlockHighRisk ···

Conditional Access policy

Delete | View policy information | View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.
Learn more

Name *
BlockHighRisk

Assignments

Users or agents (Preview)
All users included and specific users excluded

Target resources
All resources (formerly 'All cloud apps')

Network NEW
Not configured

Conditions
1 condition selected

Access controls

Grant
Block access

Session

Enable policy
Report-only | On | Off

I could create scenarios using the What If tool to see where a policy would be applied and what wouldn't be applied.

IP address
100.42.20.4

Country
Central African Republic

Filter for devices

Property	Value	Delete
Select a property...	<Pick a property and operator first>	

What if | Reset

Evaluation result

Classic policies are not evaluated by this tool.

Policies that will apply | Policies that will not apply

Search

3 policies found

Display name	Grant controls	Session Controls	State	Has filter?
CA_MFA_AllUsers	Require multifactor authentication		Report-only	No
CA_Block_LegacyAuth	Block access		Report-only	No

Phase 5 — Identity Threat Scenarios

The goal of this phase was to simulate realistic attack scenarios and document detection and investigation, and then try to remediate the attacks.

The first scenario was a password spray attack. I manually generated a few failed password attacks against users in TriadTech.

Date	Request ID	User	Application	Status	Sign-in error co...
3/5/2026, 3:23:46 PM	3e7ce11f-9e61-4c81...	TT_Isla MacLeod	My Apps	Failure	50126
3/5/2026, 3:23:34 PM	ebd1770f-e11e-4f20...	TT_Priya Nair	My Apps	Failure	50126
3/5/2026, 3:23:21 PM	defd7522-0122-42c8...	TT_Sofia Delgado	My Apps	Failure	50126
3/5/2026, 3:23:06 PM	ae99b8ab-2082-4bb...	TT_Hannah Yoon	My Apps	Failure	50126
3/5/2026, 3:22:56 PM	71086db0-bf86-4b0...	TT_Derek Patel	My Apps	Failure	50126
3/5/2026, 3:22:40 PM	cda43e3d-9511-456...	TT_Rachel Owens	My Apps	Failure	50126
3/5/2026, 3:22:37 PM	248b5e21-0efb-42f6...	TT_Rachel Owens	My Apps	Failure	50126
3/5/2026, 3:21:55 PM	6f8760dc-e17e-45dd...	TT_Ethan Brooks	OfficeHome	Failure	50126
3/5/2026, 3:21:47 PM	248b5e21-0efb-42f6...	TT_Ethan Brooks	OfficeHome	Failure	50126
3/5/2026, 3:21:36 PM	248b5e21-0efb-42f6...	TT_Aisha Mensah	OfficeHome	Failure	50126
3/5/2026, 3:21:24 PM	cda43e3d-9511-456...	TT_Brianna Scott	OfficeHome	Failure	50126
3/5/2026, 3:21:12 PM	ebd1770f-e11e-4f20...	TT_Victor Tran	OfficeHome	Failure	50126
3/5/2026, 3:20:57 PM	f411b927-987d-43e...	TT_Sandra Pierce	OfficeHome	Failure	50126
3/5/2026, 3:20:53 PM	71086db0-bf86-4b0...	TT_Sandra Pierce	OfficeHome	Failure	50126

These failed attempts actually did generate some risky sign ins.

Risky Sign-in Details

User's risk report | User's sign-ins | User's risky sign-ins | User's risk detections | Sign-in's risk detections | ...

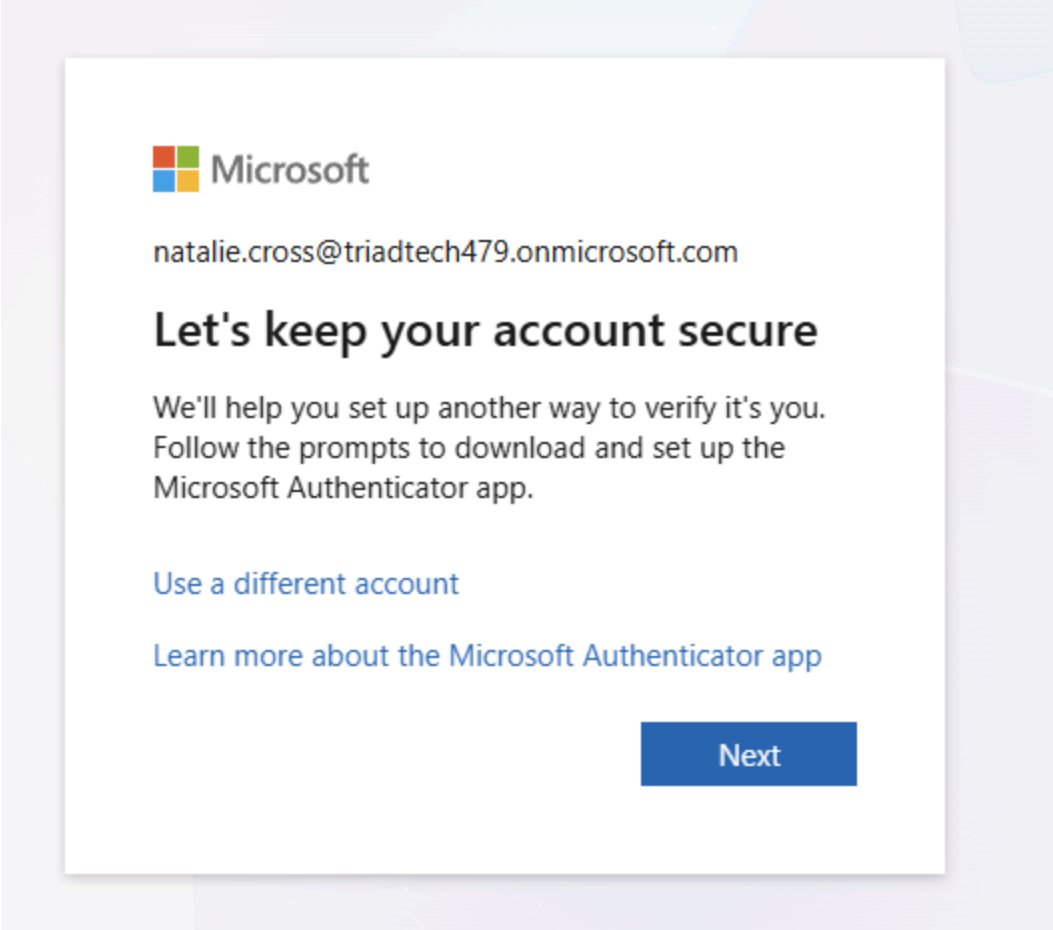
Basic info | Device info | Risk info | Multifactor authentication info | Conditional Access | Report-only

Request ID	3e7ce11f-9e61-4c81-bfe1-f4db45d58300
Correlation ID	67d61cfe-13eb-46eb-a9a4-97a88e778256
Sign-in Type	Interactive
User	TT_Isla MacLeod
Username	isla.macleod@triadtech479.onmicrosoft.com
User ID	3408fa04-1b43-4649-b704-a7aed9cf2753
Application	My Apps
Application ID	2793995e-0a7d-40d7-bd35-6968ba142197

As a response to these, I would take these steps:

- Identify all accounts targeted
- Confirm none of the attempts succeeded by filtering logins for successes from the same IP. Since this all came from my own IP, that would be impossible to show here.
- Reset passwords on targeted accounts as a precaution.
- Block source IP if pattern persists
- Enable MFA enforcement

The second scenario was to simulate an impossible travel sign in. This required the use of a VPN. I first logged in as a normal user.



I then turned on my VPN to change the IP address and logged in again as that same user. After a few minutes I checked the sign in logs and there was a change in IP address and location.

3/5/2026, 4:28:33 PM	TT_Natalie Cross	89.105.214.111	Amsterdam, Noord-Holland, NL	-	•••
3/5/2026, 4:28:33 PM	TT_Natalie Cross	89.105.214.111	Amsterdam, Noord-Holland, NL	-	•••
3/5/2026, 4:28:33 PM	TT_Natalie Cross	89.105.214.111	Amsterdam, Noord-Holland, NL	-	•••
3/5/2026, 4:28:33 PM	TT_Natalie Cross	89.105.214.111	Amsterdam, Noord-Holland, NL	-	•••
3/5/2026, 4:28:32 PM	TT_Natalie Cross	89.105.214.111	Amsterdam, Noord-Holland, NL	-	•••

To remediate this, I would follow these steps:

- Identify the two sign-in locations - in this case one is from New York and one is from Amsterdam.
- Immediately revoke all active sessions for the affected account and force a password reset.
- Require re-registration of MFA
- Investigate any potential data exfiltration

The next scenario was to simulate the dormant account. Throughout this lab, most of the accounts have been untouched, so I just had to pick a few at random. I selected:
TT_Adrian_Mercer
TT_Ben_Nakamura
TT_Aisha Mensah

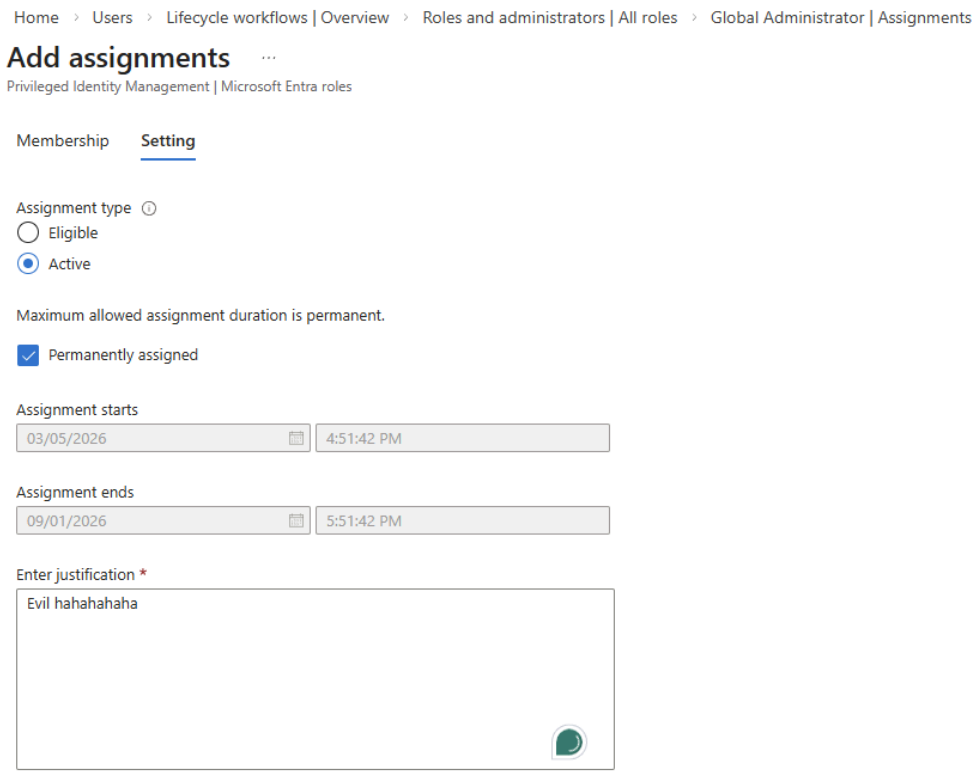
TM	TT_Adrian Mercer	adrian.mercer@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TM	TT_Aisha Mensah	aisha.mensah@Tri...	Member	No	No	TriadTech479.onmicrosoft.com
TN	TT_Ben Nakamura	ben.nakamura@Tr...	Member	No	No	TriadTech479.onmicrosoft.com

In an organization, my remediation steps for this would be:

- Export full user list with sign-in activity data
- Identify any account with no sign-in in the last 30+ days
- Cross-reference with HR to confirm employment status. If they are employed, notify their manager to investigate why their account is unused.
- If they are not employed, disable the account and schedule it for deletion.

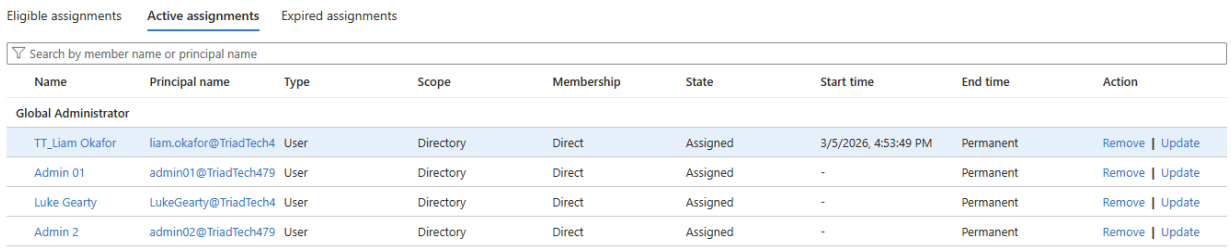
The fourth scenario is a Privilege Escalation Attempt, where a standard user account is, either accidentally or maliciously, granted a high-privilege level (Global Administrator).

I chose TT_Liam_Okafor to be the target. I assigned him to be a Global Administrator.



I looked at the audit logs to check to make sure there was an entry adding TT_Liam_Okafor to the Global Administrator group.

In Privileged Identity Management -> Assignments, he was under Active Assignments.



Name	Principal name	Type	Scope	Membership	State	Start time	End time	Action
Global Administrator								
TT_Liam Okafor	liam.okafor@TriadTech4	User	Directory	Direct	Assigned	3/5/2026, 4:53:49 PM	Permanent	Remove | Update
Admin 01	admin01@TriadTech479	User	Directory	Direct	Assigned	-	Permanent	Remove | Update
Luke Gearty	LukeGearty@TriadTech4	User	Directory	Direct	Assigned	-	Permanent	Remove | Update
Admin 2	admin02@TriadTech479	User	Directory	Direct	Assigned	-	Permanent	Remove | Update

To remediate:

- Remove TT_Liam_Okafor from the Global Administrators assignments
- Investigate who made the assignment and any potential compromises
- Check the potential actions taken during the elevated access
- Reset credentials

- Configure PIM to ensure that elevated privilege assignment requires approval

The final scenario was a stale contractor access, simulating an external contractor brought in for short-term work. This contractor was given guest access and their access was never revoked.

I first created a new external user.

Basics

Email	lukegearty@gmail.com
Display name	TT_Contractor_Reginald_Donovan
Send invite message	Yes
Message	
Cc recipient	
Invite redirect URL	https://myapplications.microsoft.com/?tenantid=763ffa68-10a7-493a-b8ab-41e69b36acdf

Properties

User type	Guest
Job title	External Consultant

Assignments

Groups

Roles

I then added this user to a few groups to simulate over-provisioning.

Add memberships | Remove memberships | Refresh | Columns | Got feedback?

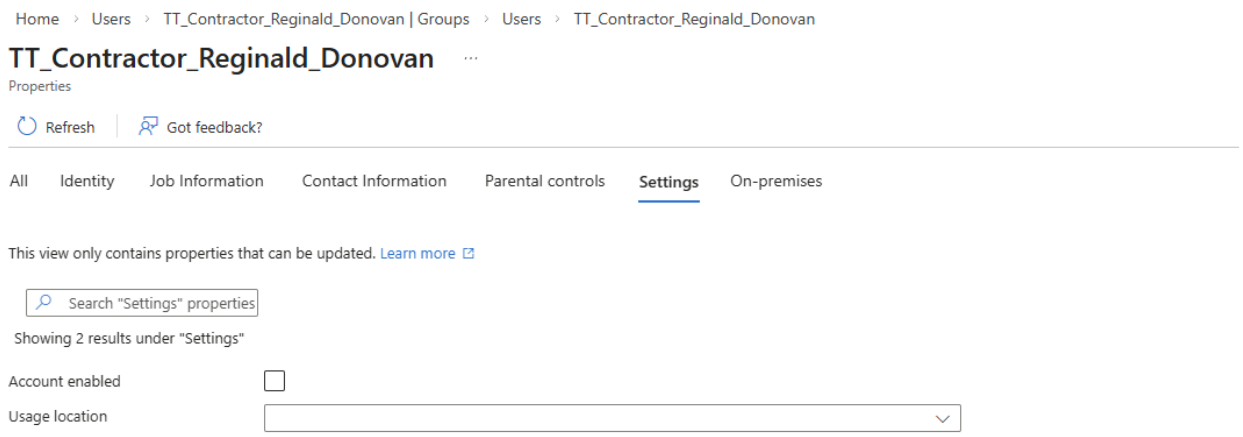
Search groups | Add filters

Name	Object Id	Group Type	Membership Type	Email	Source
Consulting_ReadOnly	d85f6f93-6ac1-4587-bce7-0a9980...	Security	Assigned		Cloud
Engineering_Dev	34b1c834-a18c-4273-9173-023cf1...	Security	Assigned		Cloud

For this scenario, the contractor was brought on, did work for 6 months and left four days ago. No offboarding was performed, the account is still active.

To remediate:

- Remove contractor's profile from both groups
- Disable the account



I would then try to implement an offboarding procedure so contractors would not retain access after leaving, and implement access reviews specifically for guest and contractor accounts.